

ТЕХНИЧЕСКОЕ ОПИСАНИЕ СИСТЕМЫ

Назначение, возможности, устройство и защита информации

Аудитория: руководители подразделений, специалисты по информационным технологиям, специалисты по защите информации

Версия документа: 1.27

Дата: 05.08.2026

СОДЕРЖАНИЕ

1. Общие сведения.....	4
1.1. Назначение документа.....	4
1.2. Состав документации.....	4
1.3. Область применения.....	4
1.4. Оформление.....	5
2. Термины и сокращения.....	5
3. Назначение системы.....	6
3.1. Решаемые задачи.....	6
3.2. Границы применения.....	7
4. Пользователи системы.....	7
4.1. Типы учётных записей.....	7
4.2. Разграничение доступа.....	8
5. Жизненный цикл заявки.....	9
5.1. Порядок обработки.....	9
5.2. Проверка по чёрным спискам.....	10
5.3. Прозрачность обработки.....	11
6. Функциональные возможности.....	11
6.1. Файловый архив бланков.....	12
7. Поиск и работа с накопленными данными.....	16
7.1. Поиск, устойчивый к способу ввода.....	16
7.2. Приведение сведений к единому виду.....	17
7.3. Повторное использование ранее заведённых сведений.....	18
7.4. Скорость поиска при накоплении данных.....	18
8. Обучение работе с системой.....	18
8.1. Обучающий тур.....	19
8.2. Встроенное руководство.....	19
8.3. Сообщение о сбое.....	19
9. Устройство системы.....	20
9.1. Состав частей.....	20
9.2. Технологическая основа.....	21
9.3. Фоновые задачи.....	21

10. Организация данных.....	22
10.1. Состав базы данных.....	22
10.2. Сохранность исторических сведений.....	23
10.3. Поиск по большим объёмам.....	23
11. Программный интерфейс.....	24
12. Обновление данных без перезагрузки.....	25
13. Защита информации.....	26
13.1. Проверка подлинности.....	26
13.2. Разграничение доступа.....	27
13.3. Защита передаваемых данных.....	27
13.4. Защита от типовых атак.....	28
13.5. Защита персональных данных при хранении.....	28
13.6. Учёт обращений к персональным данным.....	29
13.7. Согласия на обработку персональных данных.....	30
13.8. Журналы и прослеживаемость.....	32
13.9. Автоматический контроль защищённости.....	33
14. Тестирование и обеспечение качества.....	34
14.1. Уровни тестирования.....	34
14.2. Что дают тесты при сопровождении.....	35
14.3. Автоматический конвейер сборки и проверки.....	36
14.4. Проверочный стенд.....	37
15. Масштаб системы.....	37
Приложение А. Категории прав доступа.....	38

1. Общие сведения

1.1. Назначение документа

Документ описывает систему электронной подачи заявок «Бюро пропусков»: какие задачи она решает, как устроена работа пользователей, из каких частей состоит и какими средствами защищены обрабатываемые в ней сведения.

Документ предназначен для знакомства с системой перед вводом в эксплуатацию и для понимания её устройства в целом. Порядок установки и сопровождения вынесен в отдельный документ, «Руководство по развёртыванию и сопровождению».

1.2. Состав документации

Таблица 1.1 — Состав эксплуатационной документации

Документ	Кому адресован	Содержание
Техническое описание системы	Руководители, специалисты ИТ и защиты информации	Настоящий документ: назначение, возможности, устройство, защита информации
Руководство по развёртыванию и сопровождению	Подразделение информационных технологий	Требования, установка, настройка, эксплуатация, диагностика
Руководство пользователя	Заявитель	Подача заявок, работа с личным кабинетом
Руководство администратора	Сотрудник бюро пропусков с правами администратора	Пользователи, права, справочники, таблицы постов, аудит
Руководство охранника	Сотрудник поста	Работа с таблицами поста, отметка прохода, проверка пропуска

Описание программного интерфейса формируется автоматически из исходного кода и доступно в работающей системе.

1.3. Область применения

Система предназначена для организации пропускного режима на территории предприятия: оформления, согласования и учёта заявок на проход людей, проезд транспорта, внос и вынос материальных ценностей, а

также для контроля фактического нахождения людей и транспорта на территории.

1.4. Оформление

Команды, имена файлов и параметры набраны моноширинным шрифтом. Таблицы, рисунки и примеры команд нумеруются по разделам. Угловые скобки означают подстановку: <домен> заменяется фактическим значением без скобок.

Отдельно выделяются сведения, требующие повышенного внимания:

ПРИМЕЧАНИЕ. Так оформляются пояснения, которые полезно знать, но которые не влияют на порядок действий.

ВАЖНО. Так оформляются сведения, пропуск которых приведёт к неверной работе или к лишней работе по исправлению.

ОПАСНО. Так оформляются действия, последствия которых необратимы: утрата данных или утрата доступа к ним.

2. Термины и сокращения

Таблица 2.1 — Термины, применяемые в документе

Термин	Значение
Заявка	Электронный документ на доступ на территорию: кто проходит, что проезжает, что вносится, на какой срок и куда
Вложение	Часть заявки, объединяющая однородные объекты: людей, транспорт либо материальные ценности. В одной заявке их может быть несколько, с разными сроками и местами
Бланк	Печатная форма по заявке, заполняемая системой по загруженному шаблону электронной таблицы
Пост, проходная	Точка контроля доступа, за которой закреплены перечни допущенных объектов
Таблица поста	Настраиваемый перечень допущенных людей либо транспорта, с которым работает охрана
Место разгрузки	Площадка, к которой привязывается вложение заявки на внос или ввоз ценностей
Чёрный список	Перечень людей и транспорта, которым доступ запрещён
Территориальный статус	Признак нахождения человека или транспорта на территории, изменяется отметками въезда и выезда
Согласующий	Работник, чьё решение требуется для одобрения заявки

Продолжение таблицы 2.1

Термин	Значение
Принимающий	Работник бюро, принявший заявку в работу и отвечающий за её обработку
Супер-администратор	Единственная учётная запись с полным доступом, включая режим технических работ
Персональные данные	Сведения о людях: фамилия, имя, отчество, документ, удостоверяющий личность, гражданство
Маркер доступа	Электронный пропуск в саму систему: короткая строка, которую браузер прикладывает к каждому обращению вместо повторного ввода пароля. Действует 15 минут, затем продлевается автоматически
Сертификат	Электронный документ, которым сервер подтверждает браузеру свою подлинность. Обеспечивает работу по защищённому соединению, тот самый «замок» в адресной строке
Поток событий	Механизм, которым сервер сообщает открытым страницам об изменениях, чтобы данные обновлялись без нажатия кнопки обновления

3. Назначение системы

3.1. Решаемые задачи

Система предназначена для ведения пропускного режима в электронном виде: оформления заявок на доступ, их согласования, учёта фактического прохода и хранения связанных сведений.

Таблица 3.1 — Задачи, решаемые системой

Задача	Как решается
Передача заявки между участниками	Заявка доступна бюро сразу после отправки. Согласующие работают с ней в системе, передавать документ физически не требуется
Отслеживание состояния заявки	Заявитель видит текущий статус и историю изменений, не обращаясь к бюро
Сохранность сведений	Данные хранятся в базе. Записи справочников не удаляются, а переводятся в архив, поэтому заявки прошлых периодов остаются читаемыми
Поиск по накопленным данным	Поиск по части слова, с учётом раскладки клавиатуры и латинского написания. Подробнее в разделе 7
Единая картина по всем постам	Посты работают с общими данными. Отметка о въезде видна остальным без задержки
Учёт обращений к персональным данным	Каждое обращение записывается в отдельный журнал. Подробнее в подразделе 13.6

Продолжение таблицы 3.1

Задача	Как решается
Контроль запретов на доступ	Объекты заявки сверяются с чёрными списками при подаче, в том числе с учётом подмены символов. Подробнее в подразделе 5.2
Защита от повторов во вложении	Один человек и одна машина попадают во вложение только раз: повтор отклоняют и форма подачи, и сервер. Подробнее в разделе 6

3.2. Границы применения

Система обеспечивает оформление, согласование и учёт доступа. Она не управляет исполнительными устройствами: шлагбаумами, турникетами и замками. Отметка о проходе вносится работником поста.

4. Пользователи системы

4.1. Типы учётных записей

В системе заведено шесть типов учётных записей. Тип носит справочный характер и служит для классификации работников. Он не определяет, что работник может делать: объём полномочий задаётся ролями и группами прав, поэтому два работника одного типа могут иметь разный доступ, а работники разных типов - одинаковый.

Таблица 4.1 — Типы учётных записей

Тип
Пользователь
Арендатор
Подрядчик
Охранник
Руководитель
Бюро пропусков

Типы создаются и редактируются администратором, перечень не является закрытым.

ПРИМЕЧАНИЕ. Настройку системы через интерфейс (справочники, таблицы постов, права, учётные записи) ведут сотрудники бюро пропусков под учётной записью с соответствующими правами. Порядок этих действий описан в руководстве администратора.

4.2. Разграничение доступа

Права вычисляются по четырёхуровневой модели. Уровни рассматриваются по порядку, первый подходящий определяет результат.

1. Заблокированный работник не имеет прав вообще, независимо от назначенных ролей.
2. Супер-администратор имеет полный доступ, включая режим технических работ и назначение прав администратора. Такая учётная запись в системе одна, это ограничение поддерживается принудительно.
3. Администратор имеет полный доступ, кроме действий супер-администратора и кроме персональных запретов.
4. Обычный работник получает права из назначенной роли, групп прав этой роли и персонально назначенных групп. Затем применяются персональные исключения, причём запрет имеет приоритет над разрешением.

Приоритет запрета позволяет закрыть конкретному работнику отдельное действие, не разрушая назначенную ему роль и не создавая роль на одного человека.

Каталог прав содержит 53 фиксированных ключей в семи категориях. Дополнительно на каждую созданную таблицу поста автоматически создаётся десять прав: просмотр, отметка въезда, отметка выезда, карточка объекта, история, версии, выгрузка, отчёт по проходам, корзина, удаление. Заводить права для новой таблицы вручную не требуется.

Отказы в доступе записываются в журнал: работник, запрошенное действие, время. Это позволяет отличить неверно настроенные права от попытки обойти ограничения.

5. Жизненный цикл заявки

5.1. Порядок обработки

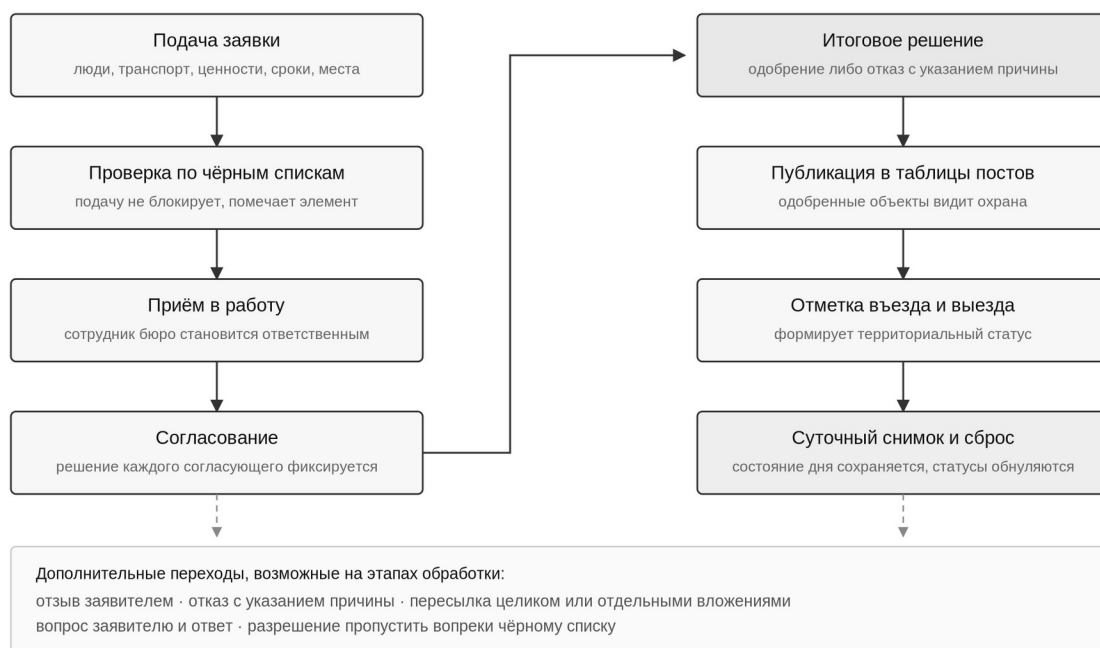


Рисунок 5.1 — Порядок прохождения заявки

Заявитель заполняет заявку: указывает организацию, добавляет вложения по людям, транспорту и ценностям, задаёт сроки и места, при необходимости прикладывает файлы, подтверждает согласие на обработку персональных данных и отправляет.

При отправке объекты заявки сверяются с чёрными списками. Порядок сверки описан в подразделе 5.2.

Заявка попадает в центр заявок. Сотрудник бюро принимает её в работу и становится ответственным. При необходимости назначаются согласующие, решение каждого фиксируется отдельно. Обработчик может задать заявителю вопрос и получить ответ, не выходя из карточки заявки, а также переслать заявку целиком или отдельными вложениями в другое подразделение.

Заявка, застрявшая на согласовании, не теряется: если решения ждут дольше заданного срока, система сама напоминает молчащему согласующему уведомлением и повторяет напоминание с заданной

периодичностью. Оба срока и само напоминание включаются администратором в настройках; по умолчанию первое уходит через трое суток и повторяется каждые трое. Когда у заявки есть обязательные согласующие, напоминания получают только они - голос остальных на исход всё равно не влияет.

После завершения обработки одобренные объекты попадают в таблицы соответствующих постов и становятся видны охране. Работник поста отмечает фактический въезд и выезд, эти отметки формируют территориальный статус и историю проходов.

Ежесуточно в заданное время система сохраняет снимок состояния таблиц и обнуляет территориальные статусы, чтобы новый день начинался с чистого листа, а состояние предыдущего оставалось доступным для разбора.

5.2. Проверка по чёрным спискам

Сверка выполняется при отправке заявки и работает на двух уровнях.

Точное совпадение. Если объект заявки совпадает с действующей записью чёрного списка, заявка не принимается, а заявитель получает отказ с пояснением.

Близкое совпадение. Сравнение выполняется не по исходной строке, а по приведённой к единому виду, поэтому обнаруживаются варианты, которыми точное сравнение обойти легко: подмена русских букв внешне похожими латинскими, замена буквы «О» на ноль в номере, опечатка, отсутствие отчества. Такой объект помечается признаком возможного совпадения с указанием, с какой записью и насколько близко он совпал.

Пометка не блокирует подачу, но **блокирует согласование заявки** до тех пор, пока по каждому помеченному объекту не будет принято явное решение пропустить его вопреки запрету. Такое решение фиксируется отдельной записью с указанием принявшего его работника, поэтому ответственность за пропуск персонализирована.

Повторные предупреждения по той же паре «объект и запись чёрного списка» после принятого решения не выводятся.

5.3. Прозрачность обработки

Заявитель в любой момент видит текущее состояние заявки и историю её изменений: когда принята в работу, кто ответственный, какие решения приняли согласующие, по какой причине отказано. Обращаться за этими сведениями к бюро не требуется.

Отметки прочтения ведутся персонально: система различает, кто именно из имеющих доступ работников открывал заявку, а не только факт открытия.

6. Функциональные возможности

Таблица 6.1 — Функциональные подсистемы

Подсистема	Возможности
Заявки	Создание, приём в работу, согласование, завершение, отказ, отзыв. Пересылка целиком и по вложениям, вопросы и ответы, история статусов, персональные отметки прочтения, напоминания молчащим согласующим
Вложения и бланки	Группировка объектов внутри заявки, настраиваемые дополнительные поля, шаблоны печатных форм с привязкой к ячейкам таблицы, формирование заполненного бланка. Выгрузка бланков в файловый архив на диске. Длинный перечень переносится на следующую страницу вместе со своей шапкой столбцов, поэтому многостраничный бланк остаётся читаемым
Транспорт	Реестр транспортных средств, привязка к заявкам и постам, отметки въезда и выезда, история проездов, добавление вне заявки
Люди	Реестр физических лиц, документы, гражданство, история проходов, прикрепление файлов
Чёрные списки	Раздельные перечни по людям и транспорту, проверка при подаче, признак возможного совпадения, разрешение пропуска вопреки запрету с фиксацией
Таблицы постов	Конструктор перечней: настраиваемые столбцы, фотографии, временные интервалы, корзина удалённых записей, суточные снимки, выгрузка
Места разгрузки	Справочник площадок, фотографии, расписания, привязка к организациям
Организации и компании	Структура арендаторов и подрядчиков, ответственные лица, привязка ресурсов, групповые операции
Аналитика и отчёты	Панель показателей, конструктор отчётов, сохраняемые шаблоны, сводные таблицы, выгрузка в электронную таблицу
Права доступа	Роли, группы прав, персональные исключения, журнал отказов

Продолжение таблицы 6.1

Подсистема	Возможности
Учётные записи	Заведение, блокировка, снятие блокировки входа после неудачных попыток, журнал входов, признак нахождения в системе и давность последнего входа, групповые операции
Принимающие заявки	Перечень работников, которым можно передать заявку в работу, и отображаемое имя, под которым заявитель видит принявшего
Новости и объявления	Публикации с форматированным текстом и изображениями, объявление-баннер на главной
Уведомления	Уведомления о событиях по заявкам, доставляются без обновления страницы
Справочники	Гражданства, марки транспорта, форматы регистрационных знаков, типы вложений, типы работников, документы, режим работы бюро
Обратная связь	Обращения работников со статусами, отправка сообщения о сбое
Обучение	Встроенное руководство по ролям и обучающий тур по интерфейсу. Подробнее в разделе 8
Обработка данных	Документ и текст согласия на обработку персональных данных, его редакция, требование согласия при входе и ход сбора. Подробнее в подразделе 13.7
Журналы и режим работ	Журнал запросов, сводный журнал изменений, журнал обращений к персональным данным, режим технических работ
Файловый архив	Выкладывание сформированных бланков на диск сервера, раскладка файлов, занятое место, ошибки записи, выгрузка задним числом. Подробнее в подразделе 6.1

Одного человека и одну машину вложение принимает только один раз: повтор отклоняют и форма подачи, и сервер. Людей система различает по паспортным данным, а когда шаблон вложения их не запрашивает - по фамилии, имени и отчеству; машины - по государственному номеру, поэтому одна машина под разными марками повтором не станет. Пробелы и регистр букв при сравнении не учитываются. Номер «По факту» конкретную машину не опознаёт, таких строк во вложении может быть несколько, а одно лицо в разных вложениях допустимо: у вложений свои сроки и места прохода.

6.1. Файловый архив бланков

Сформированные бланки система выкладывает на диск, чтобы заявка существовала не только внутри программы: папку архива можно отдать в сетевой доступ на чтение, и бумажная копия заявки открывается двойным щелчком без входа в систему.

Раскладка задаётся отдельно шаблоном каталогов и отдельно шаблоном имени файла. В них подставляются сведения заявки, поэтому папки складываются в понятную человеку структуру, а не в список номеров. Настраивают раскладку не через интерфейс, а командой на сервере: шаблон определяет, где физически лежат документы со сведениями работников, и его смена переносит дерево заявок целиком, поэтому право на такое изменение отделено от работы в системе и требует доступа к серверу. Команда показывает получающийся путь на примере действующей заявки до сохранения и отклоняет неизвестное обозначение, а само изменение записывает в журнал изменений.

Изначально путь состоит из четырёх уровней - год, месяц, день и папка заявки, в имени которой стоят дата, номер и организация. Имя файла образуют вид вложения и организация. День берётся по местному времени, а не по времени хранения в базе, поэтому вечерняя заявка не уезжает в папку следующих суток. Символы, недопустимые в именах файлов Windows, заменяются читаемыми, а слишком длинное имя папки укорачивается: путь ограничен так, чтобы файл открывался с рабочего места по сети двойным щелчком.

Рядом с бланками кладётся машиночитаемый слепок заявки: поля заявки, все люди, машины и материальные ценности по вложениям, согласования и места разгрузки одним файлом. Он нужен, чтобы сведения заявки можно было передать в другую систему учёта, не разбирая печатную форму.

И в бланке, и в слепке сведения документов записаны открытым текстом: иначе файл не открылся бы вне системы, ради чего архив и заводится. Поэтому каталог архива - хранилище персональных данных того же класса, что и база, и требования к доступу к нему те же. Подробнее в подразделе 13.5.

Выгружаются бланки тех типов вложений, у которых включено автосохранение. Тумблер стоит в карточке типа вложения и недоступен, пока архив выключен целиком или у типа нет действующего бланка.

Файлы обновляются вслед за заявкой: бланк переписывается при подаче, при изменении и по отдельной команде повторной выгрузки. Изменилось ли содержимое, система определяет по контрольной сумме: при совпадении файл не открывается вовсе, поэтому его дата и время остаются прежними и средство синхронизации на рабочий компьютер не переносит его заново. Исправление организации переносит папку целиком, а не заводит рядом вторую.

Запись идёт не в момент нажатия кнопки, а фоновой очередью: изменение заявки ставит её в очередь и будит обработчик, тот пишет файлы отдельно от работы пользователя. Заявка, для которой запись сорвалась по временной причине, откладывается и повторяется позже. Раз в сутки ночью система сверяет свой реестр выгруженных файлов с тем, что действительно лежит на диске, и дописывает пропавшее: так восстанавливаются заявки, чья очередь потерялась вместе с перезапуском сервера. Сверка идёт по недавним заявкам, глубина окна задаётся настройкой; для более ранних предусмотрена выгрузка задним числом за указанный период. Недописанные при сбое файлы убираются, частично записанный бланк на диске не остаётся.

Файлы закрытой заявки со временем замораживаются: дальнейшие правки в системе их уже не касаются. Отсчёт идёт от того момента, когда заявка перестала действовать: у отозванной - от отзыва, у остальных - от последнего дня, на который выписаны её вложения. Срок задаётся настройкой на сервере, изначально месяц. Смысл в том, что пока заявку могут поправить задним числом, файл обязан следовать за ней, а после - становится документом и больше не меняется.

Занятое место ограничивается двумя порогами. При заполнении сверх заданной доли раздела ответственным за архив уходит предупреждение - один раз на переход через край, а не потоком. Когда свободного места

остаётся меньше заданного запаса или архив упёрся в отведённый ему объём, запись останавливается и возобновляется сама, как только место появится. Заявки при этом продолжают приниматься: архив не должен доедать место, нужное самой системе.

Состояние архива видно в отдельном разделе администрирования, и разложено оно так, чтобы отвечать на вопросы дежурного, а не пересказывать устройство хранилища. Обзор показывает занятое место, отдельно число заявок, бланков и машиночитаемых описаний, свободное место на разделе с разбивкой по тому, чем оно занято, момент последней записи, число ошибок и число вложений, оставшихся без шаблона. Ниже архив разложен по месяцам и по типам вложений - видно, что занимает место. Полоса занятости подписывает каждую долю раздела при наведении. Соседняя лента перечисляет записи реестра целиком, с отбором по состоянию и счётчиком очереди: по ней видно и то, что уже записано, и то, что ждёт разбора, а сорвавшимся строкам подписан срок следующей попытки. Там же приведены действующие настройки - раскладка, пороги места и срок заморозки, - и приведены словами, с примером получающегося пути и пояснением, что произойдёт при достижении каждого порога; изменить их из интерфейса нельзя. Отсюда же исправляют ошибки записи и запускают выгрузку задним числом: за выбранный период или для бланков одного типа, когда его шаблон поправили и печатные формы нужно пересобрать.

Каждому бланку отвечает состояние выгрузки: ждёт очереди, записан, сорвался по временной причине, остался без шаблона, остановлен нехваткой места, потерял вложение. Различаются они не для порядка: временный отказ система повторяет сама, а отсутствие шаблона или места ждёт человека, и в карточке заявки работник видит это состояние рядом с вложением, не заходя в раздел администрирования. Разбор состояний приведён в руководстве по развёртыванию и сопровождению, подраздел 9.6.

Забрать сохранённое можно и не открывая сетевую папку. Из раздела администрирования выгружается всё за выбранный период одним архивом: до запуска система сообщает, сколько это файлов и какого объёма, и отказывает, когда объём выходит за отведённый предел - тогда период сужают. Архив собирается на лету и отдаётся потоком, на диске сервера он не накапливается. Отдельные файлы забирают из карточки заявки: сохранённый бланк вложения скачивается по одному, а все файлы заявки выдаются архивом. Круг допущенных здесь тот же, что при скачивании бланка: участник заявки получает все её файлы, работник поста - только по тем вложениям, которые ему и так видны. Каждое такое обращение попадает в журнал обращений к персональным данным, см. подраздел 13.6.

Доступ разграничен тремя отдельными правами: увидеть занятое место и перечень файлов может один круг работников, запускать повторную выгрузку и донаполнение - другой, выносить файлы из системы - третий. Раскладка и пороги в этот перечень не входят: они задаются на сервере, и веб-доступ их не меняет ни при каких правах.

7. Поиск и работа с накопленными данными

7.1. Поиск, устойчивый к способу ввода

Поиск рассчитан на быстрый и неаккуратный ввод. По введённой строке система строит несколько вариантов запроса и ищет по каждому.

Таблица 7.1 — Что распознаёт поиск

Ситуация	Пример ввода	Что будет найдено
Часть слова, в том числе из середины	иван	Иванов, Иваненко, Селиванов
Ввод в неверной раскладке клавиатуры	bdfyjd	Иванов
Различие в регистре	ИВАНОВ	Иванов
Номер слитно и отдельно	a123вс и а 123 вс	A123BC
Опечатка в фамилии	ИВОНОВ	Иванов

Поиск работает по фамилиям, именам и отчествам, номерам заявок, государственным регистрационным знакам, маркам транспорта,

наименованиям организаций и мест разгрузки, наименованиям работ, тексту сопроводительных писем и комментариев.

Сквозной поиск проходит по заявкам, людям, транспорту, учётным записям работников, чёрным спискам, справочникам (организации, компании, места разгрузки, таблицы постов, марки, гражданства, форматы номеров), а также по новостям, объявлениям, документам и обращениям обратной связи. Каждый раздел выдачи закрыт тем же правом, что и его страница: работник видит в подсказках только то, что ему и так доступно.

Опечатки распознаются при поиске по фамилиям внутри раздела — в центре заявок и реестрах: сравнение ведётся по близости написания, поэтому «Ивонов» найдёт Иванова. Для остальных полей поиск идёт по фрагменту строки, и опечатка в середине слова результата не даст.

Сквозной поиск опечатки распознаёт тоже: раньше он требовал точного вхождения, и один и тот же запрос в центре заявок срабатывал, а в строке сквозного поиска нет. Сравнение ведётся по той же близости написания и по тому же порогу, что и в центре заявок. Слова короче четырёх символов сравниваются только точно: на трёх символах похожим оказывается почти любое слово. Государственные знаки сравниваются с допуском тоже, но близкие по написанию номера принадлежат разным машинам, и результат стоит сверять глазами. Неверную раскладку клавиатуры и номер, набранный слитно или раздельно, сквозной поиск понимает.

Списки справочников и таблиц, которые фильтруются прямо в браузере, дополнительно распознают латинское написание русского слова: `ivanov` найдёт Иванова. При поиске заявок такое написание не распознаётся.

7.2. Приведение сведений к единому виду

Часть сведений приводится к единой форме автоматически, чтобы одинаковые по смыслу записи не расходились в написании.

- Государственные регистрационные знаки: убираются пробелы и разделители, латинские буквы, внешне совпадающие с русскими,

заменяются на русские, ноль и буква «О» приводятся к одному виду.

- Фамилии, имена и отчества: убираются лишние пробелы, приводится регистр, «е» и «ё» считаются одной буквой.
- Наименования организаций: приводится к единому виду организационно-правовая форма и кавычки. Применяется при разборе организаций, поступающих с заявками, и при модерации справочника.

Приведённая форма используется при сверке с чёрными списками и хранится рядом с исходной, поэтому исходное написание не теряется.

7.3. Повторное использование ранее заведённых сведений

Сотрудники и транспортные средства, ранее заводившиеся в системе, хранятся в реестрах. При оформлении заявки их не требуется вводить заново: в форме предусмотрен выбор из реестра.

По кнопке открывается окно со списком ранее заведённых записей, в котором есть собственный поиск и возможность отметить сразу несколько записей. Отмеченные записи добавляются в заявку вместе с ранее указанными сведениями.

7.4. Скорость поиска при накоплении данных

Для полей, по которым ведётся поиск, создано 38 специальных индексов. Они позволяют искать по фрагменту слова, не перебирая таблицу целиком, поэтому скорость поиска не падает по мере накопления данных.

8. Обучение работе с системой

Система рассчитана на работников без специальной подготовки, поэтому обучение встроено в интерфейс.

8.1. Обучающий тур

При первом входе запускается пошаговый тур: система последовательно подсвечивает элементы интерфейса и объясняет их назначение. Тур учитывает тип учётной записи: работнику поста показываются шаги про таблицы и отметку въезда и выезда, а не про подачу заявки.

Тур можно пройти повторно в любой момент. Администратор может сбросить отметку о прохождении конкретному работнику, например при переводе на другую должность.

Тур версионизируется: после существенного изменения интерфейса работникам показываются новые шаги, а не пройденный ранее старый вариант.

8.2. Встроенное руководство

В системе есть раздел справки с отдельными материалами для заявителя, охранника и администратора. Материал раздела состоит из вводного текста, перечня пунктов и прикрепленного файла. Всё это ведётся администратором в самой системе, поэтому обновление справки не требует выпуска новой версии программы.

8.3. Сообщение о сбое

Если работник столкнулся с ошибкой, он может отправить сообщение прямо из системы. Сообщение сохраняется вместе со сведениями о том, что происходило в момент сбоя, и попадает в раздел обратной связи, где обрабатывается со статусами.

9. Устройство системы

9.1. Состав частей

Система собрана из отдельных частей, каждая работает в собственном контейнере. Наружу открыта одна из них, обратный прокси. Остальные работают во внутренней сети сервера и с рабочих мест недоступны.

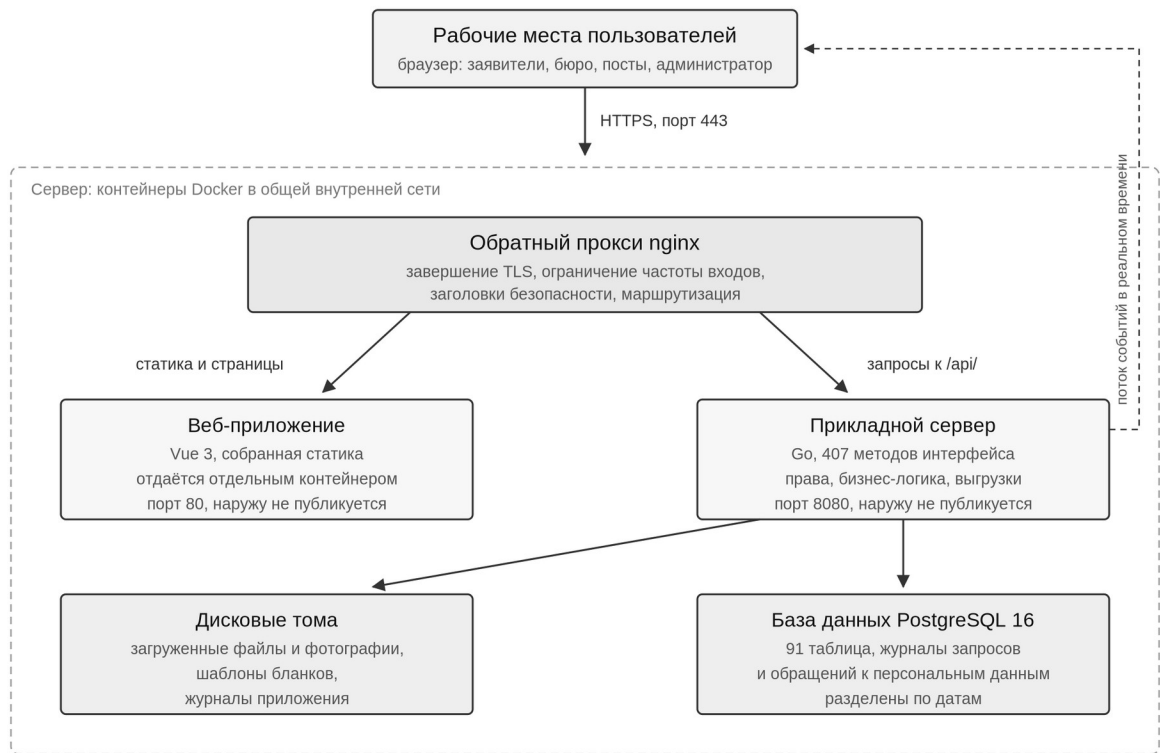


Рисунок 9.1 — Состав системы и потоки данных

Обратный прокси принимает защищённое соединение, расшифровывает его и распределяет запросы: обращения к данным уходят на прикладной сервер, всё остальное отдаёт веб-приложение. Прикладной сервер обращается к базе данных и к хранилищу файлов. Обратный поток событий идёт от прикладного сервера прямо в браузер и обновляет открытые страницы.

Таблица 9.1 — Части системы

Часть	Основа	Роль
Обратный прокси	nginx	Защищённое соединение, ограничение частоты попыток входа, заголовки безопасности, распределение запросов

Продолжение таблицы 9.1

Часть	Основа	Роль
Веб-приложение	Vue 3	Интерфейс, с которым работает пользователь в браузере
Прикладной сервер	Go	Проверка прав, обработка заявок, работа с данными, формирование выгрузок
База данных	PostgreSQL 16	Хранение всех сведений системы

9.2. Технологическая основа

Таблица 9.2 — Применённые технологии

Уровень	Технологии
Прикладной сервер	Go 1.25, веб-каркас Echo, работа с базой через GORM и драйвер pgx, формирование электронных таблиц и печатных форм
Веб-приложение	Vue 3.5, хранилище состояния Pinia, сборка Vite, построение диаграмм, редактор форматированного текста
Хранение	PostgreSQL 16 с разделением журнальных таблиц по датам и поиском по фрагментам слов
Развёртывание	Docker и Docker Compose, работа от непривилегированного пользователя

9.3. Фоновые задачи

Прикладной сервер сам выполняет периодические задачи, отдельный планировщик в операционной системе не нужен.

Таблица 9.3 — Периодические задачи

Задача	Периодичность	Действие
Архивация просроченных вложений	15 минут	Вложения с истёкшим сроком перестают действовать
Архивация журнала отказов	Сутки	Записи старше 90 суток переносятся в архив
Суточный снимок и сброс	Ежесуточно в 06:00	Сохраняется состояние таблиц постов, территориальные статусы обнуляются
Суточный отчёт по проходам	Ежесуточно в 21:30	Сохраняются итоги проходов и проездов за сутки
Фиксация пика посещаемости	Минута	Записывается наибольшее число одновременно работающих за сутки
Напоминания согласующим	Час	Согласующему, чьё решение ждут дольше заданного срока, отправляется уведомление
Пересчёт показателей аналитики	60 секунд	Панель открывается сразу, без ожидания расчёта

Продолжение таблицы 9.3

Задача	Периодичность	Действие
Обслуживание журнальных таблиц	Сутки	Создание разделов вперёд, свёртка и удаление устаревших
Уборка технического мусора	Сутки	Удаляются недействительные маркеры продления и прочитанные уведомления
Выгрузка бланков в файловый архив	15 секунд и сразу при изменении заявки	Разбирается очередь записи файлов на диск
Повтор неудавшихся выгрузок	5 минут	Заявки, чья запись сорвалась по временной причине, выгружаются заново
Сверка файлового архива с диском	Ежесуточно в 03:00	Реестр выгруженных файлов сверяется с содержимым каталога, пропавшее дописывается
Уборка недописанных файлов архива	Час	Удаляются временные файлы, оставшиеся после прерванной записи
Резервное копирование	Сутки	Снимается копия базы и файлов, устаревшие копии удаляются

10. Организация данных

10.1. Состав базы данных

База содержит 98 таблиц: справочники, учётные записи и права, заявки со связанными сущностями, реестры людей и транспорта, таблицы постов, журналы.

Две журнальные таблицы растут быстрее прочих, поэтому физически разделены по датам. Это позволяет удалять устаревшие сведения мгновенно, отбрасывая целый раздел, вместо построчного удаления, которое на больших объёмах занимало бы часы.

Таблица 10.1 — Разделение журнальных таблиц

Журнал	Разделение	Срок хранения
Журнал запросов	По суткам	Подробные записи 30 суток, далее суточные итоги
Журнал обращений к персональным данным	По месяцам	36 месяцев без свёртки

Остальные служебные записи хранятся построчно. Те из них, что обесцениваются сами, суточная задача удаляет без участия человека: это недействительные маркеры продления сеанса и прочитанные уведомления, сроки задаются параметрами установки.

История действий над сущностями, суточные слепки таблиц постов и суточные итоги журнала запросов не удаляются автоматически. Они нужны для корзины, отчётов и разбора спорных случаев, поэтому решение об их удалении принимает подразделение ИТ отдельной командой; порядок описан в руководстве по развёртыванию и сопровождению. При потоке в 50-200 заявок в сутки база прирастает на 2-4 ГБ в год, то есть надобности в такой очистке годами не возникает.

10.2. Сохранность исторических сведений

Записи справочников не удаляются физически, а переводятся в архив. Заявка прошлого года, ссылающаяся на упразднённое место разгрузки или снятую с учёта марку, остаётся полностью читаемой. Архивная запись не предлагается при заполнении новых заявок и помечается в старых.

Удалённые строки таблиц постов попадают в корзину, откуда их можно восстановить.

Отдельно от этого работает резервное копирование: ежесуточно снимается выгрузка базы, к ней прилагаются архивы загруженных файлов, копии хранятся по схеме семь суточных, четыре недельных и шесть месячных. Раз в месяц система сама проверяет, что копия разворачивается и содержит данные. Копии шифруются, ключ хранится вне сервера. Порядок настройки и восстановления описан в руководстве по развёртыванию и сопровождению.

10.3. Поиск по большим объёмам

Для поиска по фамилиям, номерам заявок, регистрационным знакам и наименованиям организаций создано 38 специальных индексов. Они

позволяют искать по фрагменту слова и с опечатками, не перебирая таблицу целиком, поэтому скорость поиска не падает по мере накопления данных.

11. Программный интерфейс

Обмен данными между браузером и сервером идёт через программный интерфейс. Он же может использоваться для интеграции с другими системами предприятия.

Зарегистрировано 483 метода в 39 группах. Ответ всегда имеет одинаковую структуру, что упрощает разбор при интеграции.

Листинг 11.1 — Структура ответа программного интерфейса

```
{
  "success": true,
  "data":    { ... },
  "meta":    { "page": 1, "limit": 20, "total": 137 },
  "error":   ""
}
```

Поле `meta` присутствует у методов, возвращающих постраничные списки: оно сообщает номер страницы, её размер и общее число записей. При ошибке поле `success` принимает значение `false`, а пояснение помещается в `error`.

Без входа в систему отвечают только семь методов: вход, продление сеанса, перечень типов работников, признак режима технических работ, контактные сведения, поток событий и выгрузка файлового архива за период. Все остальные требуют действующего маркера доступа и проходят проверку прав.

Признак режима технических работ отдаётся вместе с объявленным сообщением, сроками работ и контактами поддержки. Эти сведения публичны по назначению: их читает посетитель, которого система в этот момент не пускает внутрь.

Поток событий и выгрузка архива вынесены из-под проверки маркера по одной причине: браузер не передаёт маркер доступа ни при подключении к потоку, ни при переходе по ссылке скачивания. Вместо маркера

предъявляется одноразовый билет. Выдаёт его обычный, защищённый метод - там же проверяются право на выгрузку и допустимый объём. Билет живёт минуту, гасится при первом предъявлении и хранит в себе и учётную запись заказавшего, и границы запрошенного периода, поэтому подставить в ссылку другой период нельзя. Работник в журнале обращений к персональным данным берётся из билета, то есть выгрузка не остаётся безымянной.

Отдельно устроена выдача загруженных изображений: фотографии мест разгрузки и строк таблиц постов браузер запрашивает обычным тегом изображения, который не передаёт маркер доступа, поэтому они отдаются по прямой ссылке. Ссылка при этом неугадываема: имя файла на диске заменяется случайным, и получить его можно только из ответа метода, доступ к которому разграничен.

Описание интерфейса формируется из исходного кода при сборке, поэтому не расходится с фактической реализацией.

12. Обновление данных без перезагрузки

Открытые страницы обновляются сами: новая заявка появляется в центре заявок, отметка о въезде видна другим постам, счётчик непрочитанного меняется без нажатия кнопки обновления.

Применена схема, при которой сервер сообщает только то, какую область следует обновить, но не передаёт сами сведения. Получив сигнал, браузер выполняет обычный запрос, к которому применяются права конкретного работника. Благодаря этому по каналу обновлений невозможно узнать ничего сверх собственных полномочий: он не переносит данные.

Подключение к потоку событий авторизуется одноразовым билетом, а само соединение принудительно обновляется каждые 10 минут. При обновлении повторно проверяются права и блокировка учётной записи, поэтому отзыв доступа вступает в силу не позднее чем через 10 минут даже у работника с открытой страницей.

13. Защита информации

13.1. Проверка подлинности

Таблица 13.1 — Механизмы проверки подлинности

Механизм	Реализация
Хранение паролей	Алгоритм Argon2id, устойчивый к подбору на видеокартах. Пароли в открытом виде не хранятся и не попадают в журналы
Маркер доступа	Действует 15 минут, подписан отдельным ключом
Продление сеанса	Отдельный маркер сроком 7 суток, передаётся только по защищённому соединению
Одноразовость продления	Использованный маркер продления сразу становится недействительным
Обнаружение кражи сеанса	Повторное предъявление уже использованного маркера аннулирует всю цепочку сеансов работника
Завершение всех сеансов	Администратор может отозвать доступ работника немедленно
Защита от подбора	Блокировка учётной записи после серии неудачных попыток с нарастающим сроком и ограничение частоты попыток с одного адреса

Защита от подбора устроена так. Пять неудачных попыток за пять минут закрывают вход в учётную запись, и каждая следующая серия из пяти попыток закрывает его дольше предыдущей: сначала на минуту, затем на пять, пятнадцать, тридцать минут и на час. Час - предел, выше срок не поднимается. Отсчёт возвращается к началу после успешного входа и после суток без единой неудачной попытки; администратор может снять блокировку досрочно в карточке работника, не дожидаясь конца срока. Работник на странице входа видит, сколько осталось ждать.

Отдельно от учётной записи считаются попытки с одного сетевого адреса: те же пять неудач закрывают вход с этого адреса на минуту, и этот срок не растёт. Нарастающий срок к адресу не применяется намеренно: за одним внешним адресом работает целый отдел, и ошибки одного работника не должны запирают остальных.

Несуществующий логин закрывается на те же сроки и тем же сообщением, что и настоящий. Это сделано намеренно: если бы выдуманное имя всегда запиралось на минуту, а настоящее уходило на пять и пятнадцать,

по длительности блокировки можно было бы выяснять, какие учётные записи в системе есть.

Обнаружение кражи сеанса работает так: если маркер продления похищен и использован посторонним, законный работник при следующем продлении предъявит уже использованный маркер. Система расценит это как признак компрометации и прекратит оба сеанса, а событие останется в журнале.

13.2. Разграничение доступа

Модель прав описана в подразделе 4.2. С точки зрения защиты информации существенны три её свойства.

Проверка выполняется на сервере при каждом обращении. Скрытие кнопки или пункта меню в интерфейсе рассматривается как удобство, а не как мера защиты: работник, обратившийся к системе в обход интерфейса, получит отказ на общих основаниях.

Права вычисляются по принципу «запрещено всё, что не разрешено». Отсутствие явного разрешения означает отказ.

Каждый отказ фиксируется в журнале с указанием работника, запрошенного действия и времени.

13.3. Защита передаваемых данных

Соединение защищается протоколами TLS 1.2 и 1.3, устаревшие версии и слабые алгоритмы отключены. Обращения по незащищённому протоколу перенаправляются на защищённый.

Дополнительно передаются заголовки, ограничивающие поведение браузера: обязательное использование защищённого соединения, запрет встраивания страниц системы в чужие сайты, запрет угадывания типа содержимого, ограничение источников загружаемых ресурсов, запрет доступа к камере, микрофону и определению местоположения.

13.4. Защита от типовых атак

Таблица 13.2 — Меры против типовых атак

Угроза	Мера защиты
Внедрение команд в запрос к базе данных	Все запросы к базе параметризованы. В конструкторе отчётов имена полей подставляются только из фиксированного перечня, заданного в коде, а не из введённого пользователем текста
Выполнение чужого сценария в браузере	Форматированный текст очищается перед выводом по перечню разрешённых элементов, встроенные сценарии и обработчики событий удаляются
Обращение к чужим данным по идентификатору	Принадлежность проверяется на сервере. Перечень заявок обычному работнику возвращает только его собственные
Действия в обход интерфейса	Права проверяются на сервере при каждом обращении
Загрузка вредоносного файла	Тип определяется по содержимому файла, а не по расширению, поэтому переименование не помогает. Размер ограничен, имя файла на диске заменяется на служебное
Подбор пароля	Ограничение частоты попыток и блокировка учётной записи
Избыточная нагрузка запросами	Ограничение числа запросов на работника и отдельное, более строгое, ограничение попыток входа
Обход чёрного списка подменой букв	Записи и запросы приводятся к единому виду перед сравнением, подмена русских букв латинскими не срабатывает

13.5. Защита персональных данных при хранении

Сведения документов, удостоверяющих личность, хранятся в базе в зашифрованном виде. Применён алгоритм AES-256 в режиме, который обеспечивает одновременно скрывание содержимого и защиту от подмены.

Шифрование выполняется автоматически при записи и расшифровка при чтении, поэтому записать такие сведения в открытом виде в обход шифрования нельзя.

Поиск по зашифрованным полям решён отдельно: рядом с зашифрованным значением хранится необратимая свёртка, вычисленная с секретным ключом. Поиск ведётся по ней, что позволяет находить запись, не расшифровывая всю таблицу и не раскрывая содержимое.

Шифрование действует в базе. В бланках, которые система выкладывает в файловый архив, и в машиночитаемом слепке заявки те же сведения записаны открытым текстом: файл предназначен для открытия вне

системы, и зашифрованный он этой задачи не решал бы. Из этого следует требование к каталогу архива: он защищается наравне с базой - права на чтение только у прикладного сервера и у тех, кому папка отдана в сетевой доступ, каталог не может находиться внутри общедоступных каталогов системы, и прикладной сервер это проверяет при запуске. Порядок описан в руководстве по развёртыванию и сопровождению.

ОПАСНО. Ключ шифрования является единственным способом прочитать эти сведения. При его утрате данные не восстанавливаются ни из резервной копии базы, ни средствами разработчика: копия содержит те же зашифрованные значения. Порядок хранения ключа описан в руководстве по развёртыванию и сопровождению.

13.6. Учёт обращений к персональным данным

Ведётся отдельный журнал обращений к сведениям о людях. Записываются работник, характер действия (просмотр, создание, изменение, удаление), затронутый раздел, сетевой адрес, время и результат.

Журнал доступен администратору в разделе администрирования системы, с фильтрами по работнику, действию и периоду. Открывается он по отдельному праву, то есть доступ к самому журналу тоже разграничен.

Записи хранятся 36 месяцев и не удаляются вместе с обычным журналом запросов. Запись выполняется в фоне и не замедляет работу пользователя, при этом сведения о запросе снимаются до передачи в фоновую задачу, что исключает их искажение.

Наравне с обращениями к карточкам людей учитывается и вынос сведений файлами. В журнал попадают выгрузка заполненного бланка, выгрузка файлового архива за период, скачивание отдельного файла архива и архива одной заявки, просмотр перечня выложенных файлов и оценка объёма выгрузки. Это самый массовый вынос сведений из системы: один архив за месяц уносит бланки сотен заявок, и учитывать его поштучно важнее, чем открытие одной карточки. Выгрузка за период идёт по одноразовому билету

и заголовка с маркером доступа не несёт, поэтому работник в записи определяется по билету, а не по запросу.

13.7. Согласия на обработку персональных данных

При подаче заявки заявитель подтверждает согласие на обработку персональных данных. Фиксируется факт согласия, его вид, сетевой адрес и сведения о браузере в момент подтверждения, а также время. Отзыв согласия поддерживается и также фиксируется временем.

Вместе с согласием сохраняются редакция текста и его контрольная сумма. Редакция отвечает на вопрос, какое требование выполнял работник, контрольная сумма - какой именно текст он видел: администратор может поправить формулировку, не повышая редакцию, и без контрольной суммы подтвердить содержание принятого текста было бы нечем. Обе величины ставит сервер по текущим настройкам, из запроса они не принимаются.

Документ об обработке персональных данных публикуется администратором в системе и доступен по ссылке из формы подачи заявки. Если задан текст согласия, на этой странице показывается он - тот же текст, который работник подтверждает при входе; загруженный файл остаётся доступным для скачивания. Когда текст не задан, страница показывает сам файл.

Обязательное согласие при входе. Администратор может потребовать согласие от всех работников: в разделе «Обработка данных» включается признак и задаётся текст согласия. Пока признак выключен или текст не заполнен, требование не действует и работа идёт обычным порядком.

Текст можно набрать в редакторе или получить из загруженного документа: при загрузке файла его содержимое переносится в редактор сразу. Разбор восстанавливает абзацы, нумерованные пункты, маркированные списки и заголовки; поддерживаются форматы PDF, DOCX и XLSX, для остальных текст вводится вручную. Таблицы разбор не воспроизводит, а собственная нумерация текстового процессора в содержимое файла не

входит, поэтому результат рассчитан на вычитку администратором перед сохранением.

Работник, не давший согласия, видит окно с текстом. До согласия ему доступны только само согласие, чтение опубликованного документа и выход из системы; остальные действия система отклоняет. Супер-администратор проходит всегда - иначе ошибку в настройке согласия было бы невозможно исправить через интерфейс.

У текста есть редакция. При сохранении изменённого текста система спрашивает администратора, запросить ли согласие заново у всех: изменённый текст - это новая редакция, и подтверждать её обычно надо заново, но правка опечатки того не стоит. По утвердительному ответу редакция повышается тем же действием, что и сохранение текста, - отдельные шаги оставляли бы промежуток, в котором работникам показывают новый текст, а достаточным считается согласие, данное прежнему. Отказ сохраняет текст, не трогая редакцию. Повысить редакцию без правки текста можно отдельной командой в том же разделе. Согласие работника считается действующим, пока его редакция не ниже требуемой.

Ход сбора виден в том же разделе: доля подтвердивших текущую редакцию и поимённый список тех, кто ещё нет, с выгрузкой в электронную таблицу. Счёт ведётся по тем работникам, кого требование реально касается: без учётной записи супер-администратора, без архивных и заблокированных. Пока требование выключено, сбор не идёт и сводка сообщает об этом, а не показывает нулевую долю.

Пока согласия нет, персональные данные работника не видят другие. Скрываются и фамилия с именем и отчеством, и рабочие контакты - почта и телефон. Вместо ФИО система показывает остальным логин учётной записи: в списках работников и заявок, в истории, вопросах, отметках прочтения, на экране поста, в справочниках, журналах, отчётах и аналитике. Логин выбран намеренно: подпись вида «данные скрыты» сделала бы несколько строк неразличимыми, и согласующего в списке было бы не

выбрать. Сквозной поиск, пока данные скрыты, по почте и телефону не ищет вовсе, иначе подсказка подтверждала бы, чей это адрес.

Скрытие касается только показа. Сами данные хранятся как были, и правка карточки работника их не затирает: поля, которых нет в запросе, система не трогает.

Скрытие снимается, как только работник согласился хотя бы раз: признаком служит наличие согласия вообще, а не подтверждение текущей редакции - иначе правка текста разом обезличила бы всех, кто ещё не успел перезайти. Пока требование согласия выключено, не скрывается ничего.

Отзыв согласия. Работник отзывает своё согласие сам - в личном кабинете, отметкой согласия в верхней части страницы: она же показывает дату, когда согласие было дано. Если он обратился в бюро пропусков, отозвать согласие за него может администратор из карточки работника. В обоих случаях доступ закрывается сразу: система снова показывает окно согласия, и до нового подтверждения работать в ней нельзя - об этом предупреждает вопрос, который задаётся перед отзывом.

Выдача и отзыв попадают в историю учётной записи. В записи о выдаче сохраняется редакция текста, с которой работник согласился; в записи об отзыве видно, отозвал он согласие сам или это сделал администратор по его обращению. В разделе работников состояние согласия видно, не открывая историю: у не подтвердившего вместо фамилии стоит пометка, а в карточке - дата согласия либо отметка, что его нет.

13.8. Журналы и прослеживаемость

Таблица 13.3 — Журналы системы

Журнал	Что фиксирует	Кому доступен
Журнал запросов	Все обращения к системе: работник, действие, результат, длительность	Администратору и работникам с правом просмотра
Журнал обращений к персональным данным	Обращения к сведениям о людях	По отдельному праву

Продолжение таблицы 13.3

Журнал	Что фиксирует	Кому доступен
Журнал изменений	Кто, когда и что изменил в сущностях системы	Администратору
Журнал отказов в доступе	Попытки выполнить действие без прав	Администратору
Журнал входов	Входы, выходы, неудачные попытки, блокировки и их снятие администратором	Администратору

Совокупность журналов позволяет восстановить картину по любому вопросу вида «кто это сделал и когда».

Адрес запроса записывается в журнал с затёртыми значениями секретных параметров: одноразовый билет, маркер доступа и ключ выгрузки сохраняются как признак «параметр был», без самого значения. Сделано это потому, что сроки жизни у секрета и у журнала несопоставимы: билет действует меньше минуты и гасится при первом предъявлении, а журнал хранится месяцами, читается через интерфейс и выгружается в электронную таблицу. Особенно это важно для файлового архива, где билет открывает выгрузку бланков с паспортными сведениями.

13.9. Автоматический контроль защищённости

Поиск уязвимостей встроен в конвейер сборки и выполняется при каждом изменении программы, а также еженедельно по расписанию, когда сама программа не менялась. Последнее важно: сведения об уязвимости часто появляются уже после выпуска версии.

Таблица 13.4 — Средства автоматического поиска уязвимостей

Средство	Что проверяет	Поведение при обнаружении
govulncheck	Библиотеки серверной части на уязвимости из базы уязвимостей Go. Учитывает, вызывается ли уязвимый код фактически, что отсеивает ложные срабатывания	Сборка прерывается
npm audit	Библиотеки интерфейса, участвующие в сборке	Сборка прерывается при уровне «высокий» и выше

Продолжение таблицы 13.4

Средство	Что проверяет	Поведение при обнаружении
Trivy	Собранный образ контейнера целиком: системные пакеты операционной системы и библиотеки внутри образа	Сборка прерывается при уровне «критический» и «высокий»

Прерывание сборки означает, что версия с известной уязвимостью не может быть выпущена: её невозможно собрать и выложить, пока уязвимость не устранена.

Обновления библиотек предлагаются автоматически, сгруппированные по назначению, и проходят полный набор тестов до применения. Благодаря этому зависимости не устаревают незаметно.

Дополнительно проведён аудит разграничения доступа по методике проверки функциональной авторизации: последовательно проверялось, что каждое действие недоступно работнику без соответствующего права. Выявленные несоответствия устранены. Чтобы они не появились вновь при развитии системы, добавлены автоматические проверки, закрепляющие требуемое разграничение: попытка выпустить версию, в которой действие открыто без права, будет остановлена на этапе проверок.

14. Тестирование и обеспечение качества

14.1. Уровни тестирования

Качество обеспечивается тремя уровнями автоматических тестов. Каждый уровень ловит свой класс ошибок, и ни один не заменяет остальные.

Таблица 14.1 — Состав автоматических тестов

Уровень	Инструмент	Объём	Что покрывает
Бэкенд-тесты, модульные и интеграционные	Штатное средство тестирования Go	1 552 теста в 262 файлах	Обработку заявок, разграничение доступа, работу с данными, выгрузки, шифрование
Фронтенд-тесты	Vitest	3 258 тестов в 366 файлах	Поведение экранов и элементов, обработку данных на стороне браузера, хранилища состояния

Продолжение таблицы 14.1

Уровень	Инструмент	Объём	Что покрывает
E2E-сценарии, сквозные	Playwright	168 тестов в 44 файлах	Работу системы целиком в браузере от входа до результата, а также прямые обращения к программному интерфейсу
Всего		4 978	

Существенная особенность: бо́льшая часть бэкенд-тестов выполняется **на настоящей базе данных**, которая разворачивается специально для прогона, а не на её упрощённой замене. Это медленнее, но обнаруживает ошибки в запросах, ограничениях целостности и правах, которые упрощённая замена пропустила бы в принципе. Точное число таких файлов приведено в разделе 15.

E2E-сценарии запускаются в настоящем браузере и повторяют действия работника: заполнение формы заявки, приём в работу, отметку въезда на посту, открытие разделов администрирования.

Отдельно поддерживаются тесты, закрепляющие разграничение доступа: они пытаются выполнить действие без права и требуют получить отказ. Такие тесты не дают случайно открыть доступ при доработках.

14.2. Что дают тесты при сопровождении

Набор тестов нужен не сам по себе, а как страховка при внесении изменений. Практический эффект такой.

- Ошибка обнаруживается до выкладывания, а не пользователем на рабочем сервере.
- Доработка одной части системы, случайно сломавшая другую, будет остановлена: E2E-сценарии проходят по основным рабочим процессам целиком.
- Разграничение доступа защищено от случайного ослабления.

- Известные уязвимости в используемых библиотеках обнаруживаются автоматически, включая появившиеся уже после выпуска версии.

14.3. Автоматический конвейер сборки и проверки

Конвейер построен на GitHub Actions и запускается сам. Он состоит из трёх процессов с разными условиями запуска: это существенно, потому что не всё выполняется на каждое изменение.

Основной конвейер. Запускается на каждое изменение в основной ветке и на каждый запрос на слияние.

Таблица 14.2 — Этапы основного конвейера

Этап	Что выполняется
Определение изменений	Анализируется, какие части затронуты, чтобы не запускать лишнее
Проверка описания изменения	Описание проверяется на соответствие принятому формату
Статический анализ	Код серверной части проверяется на подозрительные конструкции
Бэкенд-тесты	Разворачивается база данных, тесты прогоняются с обнаружением состязаний за общие данные
Проверка стиля интерфейса	Код интерфейса проверяется на соответствие правилам оформления
Фронтенд-тесты	Прогон тестов интерфейса
Сборка образов	Собираются образы контейнеров, проверяется, что процесс внутри работает от непривилегированного пользователя, после чего проверенные образы помещаются в хранилище образов
Выкладывание на стенд	Только при попадании изменения в основную ветку: стенд забирает готовые образы из хранилища и перезапускается
Итоговый контроль	Отдельный этап, который завершается неудачей, если неудачей закончился любой предыдущий

Сквозные сценарии. Выполняются при запросе на слияние в основную ветку, если изменения затронули интерфейс или серверную часть. Прогон идёт в браузере на четырёх параллельных потоках, отчёт сохраняется при неудаче.

Сканирование уязвимостей. Выполняется на изменения в основной и производственной ветках, а также еженедельно по расписанию. Расписание нужно потому, что сведения об уязвимости часто появляются уже после

выпуска версии, когда сама программа не менялась. Состав средств приведён в подразделе 13.9.

Изменение, не прошедшее основной конвейер, к выпуску не допускается: итоговый контроль перекрывает выпуск, если хотя бы один этап завершился неудачей.

Обновления используемых библиотек предлагаются автоматически, сгруппированные по назначению, и проходят те же проверки, что и остальные изменения.

14.4. Проверочный стенд

Помимо рабочего сервера поддерживается отдельный стенд с той же системой. Изменения попадают на него автоматически после успешного прохождения проверок, что позволяет посмотреть их вживую до выкладывания на рабочий сервер.

Стенд закрыт запросом имени и пароля на входе и содержит отдельную базу, поэтому эксперименты на нём не затрагивают рабочие данные.

Порядок работы со стендом и порядок выкладывания на рабочий сервер описаны в руководстве по развёртыванию и сопровождению.

15. Масштаб системы

Сведения приводятся для оценки объёма разработки и трудоёмкости сопровождения.

Таблица 15.1 — Количественные показатели

Показатель	Значение
Объём исходного кода	387 860 строк в 1 370 файлах
Серверная часть	80 056 строк без тестов: 156 служб, 68 обработчиков, 75 моделей данных
Экраны и элементы интерфейса	182 547 строк: 38 экранов, 203 элемента
Методы программного интерфейса	483 в 39 группах
Таблицы базы данных	98
Автоматические тесты	4 978
Файлов бэкенд-тестов на настоящей базе	187

Объём исходного кода приведён по файлам серверной части и интерфейса вместе с тестами; сторонние библиотеки и сформированное из кода описание программного интерфейса в подсчёт не входят.

Конфигурация сервера, приведённая в руководстве по развёртыванию и сопровождению, рассчитана на 1000-1500 одновременно работающих пользователей. Значение получено расчётом по параметрам базы данных и прикладного сервера; нагрузочные испытания на целевом оборудовании подтвердят или уточнят его.

Приложение А. Категории прав доступа

Таблица А.1 — Категории прав

Категория	Содержание
Разделы навигации	Доступ к экранам системы
Элементы верхней панели	Действия, доступные из шапки
Центр заявок	Просмотр и обработка заявок, приём в работу, решения
Карточки объектов	Просмотр карточек транспорта и людей, история
Реестры	Работа с реестрами людей и транспорта
Администрирование	Учётные записи, права, справочники, журналы
Обзор и руководство	Доступ к разделам встроенной справки
Таблицы постов	Создаются автоматически для каждой таблицы: просмотр, отметки въезда и выезда, карточка, история, версии, выгрузка, отчёт по проходам, корзина, удаление

Два действия доступны исключительно супер-администратору: включение режима технических работ и назначение прав администратора.

ЛИСТ РЕГИСТРАЦИИ ИЗМЕНЕНИЙ

В таблице фиксируются изменения документа. Версия повышается при выпуске новой редакции: вторая цифра при уточнениях и дополнениях, первая при переработке структуры или существенном изменении требований.

Таблица - Регистрация изменений

Версия	Дата	Содержание изменения	Внёс
1.0	28.07.2026	Первая редакция	
1.1	28.07.2026	Сверка с реализацией: уточнены количественные показатели, состав прав таблиц постов и поведение поиска	
1.2	28.07.2026	Описана защита вложения от повторного добавления одного человека или одной машины	
1.3	28.07.2026	Описан режим технических работ: объявляемые сроки и контакты, снятие режима по истечении срока	
1.4	30.07.2026	Обновлены количественные показатели; описан перенос длинного перечня в бланке вместе с шапкой столбцов	
1.5	30.07.2026	Обновлены количественные показатели: объём кода, число тестов и методов программного интерфейса	
1.6	30.07.2026	Описано обязательное согласие на обработку персональных данных при входе	
1.7	30.07.2026	Дополнен состав записи о согласии: редакция текста и его контрольная сумма; описан показ текста согласия на странице документа	
1.8	30.07.2026	Обновлены количественные показатели: объём кода, число тестов и сквозных сценариев	
1.9	30.07.2026	Описаны напоминания молчащим согласующим, признак нахождения работника в системе и перечень принимающих заявки	
1.10	30.07.2026	Описан просмотр хода сбора согласий администратором: доля подтвердивших и список остальных	
1.11	30.07.2026	Описана защита от подбора пароля с нарастающим сроком блокировки входа и её досрочное снятие администратором	
1.12	31.07.2026	Описан перенос текста согласия из загруженного документа и повторный запрос согласия при изменении текста; обновлены количественные показатели	
1.13	31.07.2026	Уточнено, что несуществующий логин запирается на те же сроки и тем же сообщением, что настоящий	
1.14	31.07.2026	Описано скрытие фамилии работника, пока он не дал согласия на обработку персональных данных	

Версия	Дата	Содержание изменения	Внёс
1.15	31.07.2026	Описаны суточная уборка недействительных маркеров продления и прочитанных уведомлений и сроки хранения по группам; обновлены количественные показатели	
1.16	31.07.2026	Описан отзыв согласия на обработку персональных данных, запись выдачи и отзыва в историю учётной записи; уточнён состав сквозного поиска	
1.17	31.07.2026	Уточнено поведение поиска при опечатках; обновлены количественные показатели	
1.18	31.07.2026	Уточнено, что до согласия скрываются и рабочие контакты работника	
1.19	31.07.2026	Описан файловый архив бланков: раскладка по шаблонам, обновление и заморозка файлов, ограничение занятого места	
1.20	01.08.2026	Файловый архив описан целиком: слепок заявки, фоновое наполнение и ночная сверка, пороги места, раздел администрирования; отмечено, что сквозной поиск понимает опечатки	
1.21	01.08.2026	Лист регистрации изменений разделён по документам: у каждого своя редакция и свой перечень изменений	
1.22	03.08.2026	Файловый архив: раскладка каталогов по умолчанию, сверка содержимого по контрольной сумме и выгрузка сохранённых бланков из системы; описаны выдача выгрузки по одноразовому билету и учёт таких обращений в журнале персональных данных	
1.23	04.08.2026	Сверка раздела о файловом архиве с реализацией: раздел администрирования показывает месяц последней записи, отдельные файлы забирают из карточки заявки, уточнён срок жизни ссылки на выгрузку	
1.24	04.08.2026	Описано, что значения одноразовых билетов и маркеров доступа в журнал запросов не попадают	
1.25	04.08.2026	Описано состояние выгрузки, которое бланк получает в архиве и показывает в карточке заявки	
1.26	04.08.2026	Уточнён конвейер проверок: проверенные образы помещаются в хранилище, стенд забирает готовые образы оттуда	
1.27	05.08.2026	Уточнено описание раздела файлового архива: состав показателей обзора, лента записей реестра, представление действующих настроек	

Версия	Дата	Содержание изменения	Внёс